# Clase 3 · Normatividad: de TCSEC a ISO/IEC 27002:2022

Seguridad Informática Básica · Dra. Cintia Quezada Reyes · jueves 3 sep 2026 · Tema 1 (1.2 y 1.3) · Apuntes y resumen de estudio

## PARTE 1 · Apuntes completos

### 1. Normas, estándares y normatividad

- **Norma:** "algo que es obligatorio". **Estándar:** "son recomendaciones". **Normatividad:** leyes, reglamentos, procedimientos o criterios que se siguen para implementar algo; guía de conducta técnica.
- Depende del país: Reino Unido obliga por ley a basarse en BS 7799; en **México NOM = obligatoria, NMX = voluntaria**.
- Ejemplo: un switch de Capa 2 debe cumplir la Capa de Enlace de **ISO 7498** (OSI) para ser compatible.

Error común: usar norma y estándar como sinónimos.

### 2. Los tres estándares fundacionales

| Estándar | Origen | Escala |
|---|---|---|
| **TCSEC** ("Libro Naranja") | Depto. de Defensa de EE. UU., 1983; militar, confidencialidad | Divisiones **D** (mínima), **C** (discrecional), **B** (obligatoria), **A** (verificada) |
| **ITSEC** | Comisión Europea, 1990/1991 | Funcionalidad **F1–F10** y garantía **E0–E6** (7 niveles), por separado |
| **CTCPEC** | Canadá, 1988; solo productos | **T0–T7** (8 niveles) |

### 3. Common Criteria / ISO/IEC 15408

Unifica a los anteriores para homogeneizar productos, servicios y sistemas. Garantía **EAL1–EAL7**.

- Públicos: **desarrolladores**, **evaluadores**, **usuarios**.

| Término | Significado |
|---|---|
| **TOE** | Objeto de evaluación (firewall, chapa biométrica) |
| **PP** | Perfil de protección: requisitos que debe cumplir el TOE para un nivel |
| **ST** | Meta de seguridad: "a lo que quiero llegar, puntualmente" |

- Parte 1: introducción y modelo general. Parte 2: requerimientos **funcionales** (familias con "F": auditoría, comunicación, cripto, privacidad). Parte 3: requerimientos de **garantía** (entrega, operación, documentación).

Error común: confundir TOE/PP/ST/EAL, o evaluar un producto como si fuera toda la empresa.

## 4. BS 7799 → ISO/IEC 17799 → serie 27000

- **BS 7799** (Reino Unido, 1995): protección integral de la información de toda la empresa. Parte 1: Código de prácticas; Parte 2: Especificación (origen del **SGSI/ISMS**).
- **ISO/IEC 17799:** adopción internacional; 10 dominios (2000) → 11 (2005).

| Norma | Qué es | Equivale a |
|---|---|---|
| **ISO/IEC 27001** | Requisitos del SGSI: **"qué hacer"**; actualizada oct 2022 | BS 7799 Parte 2 |
| **ISO/IEC 27002** | Buenas prácticas con ejemplos: **"cómo hacerlo"**; nombrada así en 2007 | BS 7799 Parte 1 |

- Dominios: 10 (2000) → 11 (2005) → **14 (2013)**, con criptografía como dominio propio.

## 5. ISO/IEC 27002:2022 (febrero)

- "Seguridad de la información, ciberseguridad y protección de la privacidad — Controles de seguridad de la información".

> **El cambio (examen)**
> De **14 dominios** a **4 secciones** (organizacionales, personas, físicas, tecnológicas) **+ 2 anexos** (atributos y equivalencia con 2013). Cláusulas 1–4 introductorias; buenas prácticas desde la **Cláusula 5**. Motivo: ciberterrorismo, ciberguerra y teletrabajo por la pandemia.

## 6. HIPAA, NIST, COBIT

- **HIPAA:** EE. UU., 1996; confidencialidad de datos médicos.
- **NIST:** Instituto Nacional de Estándares y Tecnología de EE. UU.
- **COBIT:** marco transversal para **matrices de riesgo**: 🔴 crítico, 🟠 alto, 🟡 medio, 🟢 bajo.

## 7. Casos

- WhatsApp cifrado extremo a extremo, pero vulnerable si fotografían tu pantalla.
- Firmas: peritos ven si el trazo fue continuo y la presión; la firma digital añade metadatos y QR al original.
- Polígrafo no aceptado en juicios en EE. UU.
- UNAM (Dejesca, hoy DGTIC) 2001–2005: intrusiones desde China; contra las 11 áreas de ISO 17799 el cumplimiento llegaba como máximo a **25 %**; motivó el CERT UNAM.
- **Patentar** a tu nombre lo que desarrolles con tus recursos antes de mostrarlo a la empresa (exalumno pagado con 30 días en Europa).
- No se pedirá memorizar cláusulas; las normas se consultan. Se evalúa el análisis.

## PARTE 2 · Resumen para estudiar

*Versión corta de lo que más probablemente se pregunta. Léela primero y vuelve a la Parte 1 si algo no queda claro.*

| Concepto | Para recordar |
|---|---|
| Norma / estándar | Obligatoria / recomendación (NOM / NMX) |
| TCSEC | 1983, militar, D–C–B–A |
| ITSEC | Europa, F1–F10 y E0–E6 |
| CTCPEC | Canadá 1988, T0–T7 |
| CC / ISO 15408 | EAL1–EAL7; TOE, PP, ST |
| 27001 / 27002 | Qué hacer (SGSI) / cómo hacerlo |
| 27002:2022 | 14 dominios → 4 secciones + 2 anexos |
| COBIT | Matriz de riesgo por colores |